3. Auditoría de Sistemas Informáticos (Endpoints Linux)

3.1. Descripción del sistema analizado y herramientas de análisis

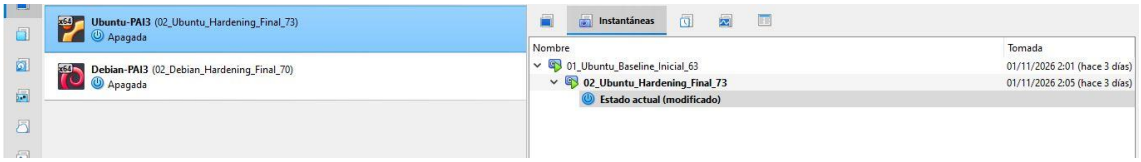
Para la realización de las pruebas de auditoría y endurecimiento (*hardening*) de la infraestructura base, se desplegaron dos entornos virtuales independientes sobre el hipervisor Oracle VM VirtualBox:

- **Endpoint 1:** Ubuntu 24.04 LTS (x86_64), configurado como estación de trabajo cliente.
- **Endpoint 2:** Debian 12 Bookworm (x86_64), configurado como servidor de infraestructura base.

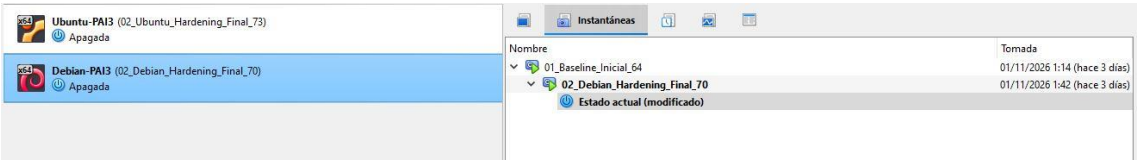
Como motor central de análisis de seguridad se utilizó **Lynis**, una herramienta de auditoría automatizada y de código abierto orientada a sistemas tipo Unix. Lynis realiza un escaneo exhaustivo y no destructivo del sistema operativo, evaluando configuraciones contra estándares como CIS Benchmarks e ISO 27001. Su análisis abarca la pila de red, directivas del kernel, sistemas de ficheros, autenticación PAM, servicios en ejecución y privilegios de usuarios, consolidando el resultado cuantitativo en el **Hardening Index** (escala de 0 a 100).

Para garantizar la reproducibilidad, la integridad de los resultados y el control de versiones técnico durante el proyecto, se aplicó una metodología de cuatro fases respaldada por el sistema de instantáneas (*snapshots*) de VirtualBox:

1. **Línea base (*baseline*):** Ejecución de la auditoría inicial sobre la instalación limpia y generación de la instantánea de congelación (01_Baseline_Inicial_*).
2. **Remediación:** Implementación modular de directivas de endurecimiento automatizadas mediante scripts de despliegue (harden.sh).
3. **Re-auditoría y verificación:** Ejecución de una segunda auditoría completa para evaluar la mitigación de vulnerabilidades y validar la superación del umbral fijado (≥ 70).
4. **Empaquetado y estado final:** Extracción de registros brutos (lynis.log, lynis-report.dat) en contenedores comprimidos .tar.gz y captura de la instantánea definitiva (02_*_Hardening_Final_*).



"Figura 3.1: Árbol de instantáneas de Ubuntu-PAI3 en VirtualBox mostrando los estados Baseline Inicial (63) y Hardening Final (73)")



"Figura 3.2: Árbol de instantáneas de Debian-PAI3 en VirtualBox mostrando los estados Baseline Inicial (64) y Hardening Final (70)")

3.2. Plan de pruebas y resultados

El plan de remediación se enfocó en subsanar de forma sistemática los avisos (*warnings*) y recomendaciones (*suggestions*) detectadas por Lynis tras la auditoría inicial. Las contramedidas aplicadas se estructuraron en cuatro vectores de actuación:

1. Filtrado perimetral y seguridad de la pila de red

- **Cortafuegos Host-Based (UFW):** Se habilitó el servicio UFW estableciendo una política por defecto restrictiva de bloqueo entrante (deny incoming) y permiso de tráfico saliente legítimo (allow outgoing).
- **Protección del núcleo vía sysctl (/etc/sysctl.d/99-hardening.conf):**
    - Validación de ruta inversa para mitigar suplantación de IP (*IP spoofing*): net.ipv4.conf.all.rp_filter = 1 y net.ipv4.conf.default.rp_filter = 1.
    - Protección frente a ataques de denegación de servicio por saturación SYN (*SYN Flood*): net.ipv4.tcp_syncookies = 1.
    - Descarte de paquetes con enrutamiento de origen: net.ipv4.conf.all.accept_source_route = 0.
    - Ignorado de mensajes broadcast ICMP para mitigar ataques de amplificación (*Smurf attacks*): net.ipv4.icmp_echo_ignore_broadcasts = 1.

2. Endurecimiento del Kernel y control del sistema de archivos

- **Blindaje de enlaces simbólicos y duros:** Se configuró fs.protected_symlinks = 1 y fs.protected_hardlinks = 1 para impedir ataques de condiciones de carrera (*race conditions*) y escaladas locales mediante enlaces maliciosos en carpetas públicas temporales (/tmp, /var/tmp).
- **Restricción de punteros y registros del núcleo:** Se inyectó kernel.kptr_restrict = 2 para ocultar las direcciones de memoria del kernel a usuarios sin privilegios (dificultando exploits basados en *Return-Oriented Programming* o ROP) y kernel.dmesg_restrict = 1 para proteger los mensajes del buffer de arranque.
- **Control de volcados de memoria:** Se anuló la generación de volcados en procesos con privilegios elevados mediante fs.suid_dumpable = 0.

3. Fortalecimiento de políticas de autenticación (PAM)

- Mediante el módulo pam_pwquality configurado en /etc/security/pwquality.conf, se erradicó el uso de contraseñas débiles o previsibles imponiendo:
    - Longitud mínima de 12 caracteres (minlen = 12).
    - Requisito estricto de concurrencia de al menos una mayúscula (ucredit = -1), una minúscula (lcredit = -1), un dígito numérico (dcredit = -1) y un carácter especial (ocredit = -1).
    - Obligatoriedad de cambio de al menos 3 caracteres respecto a claves anteriores (difok = 3).

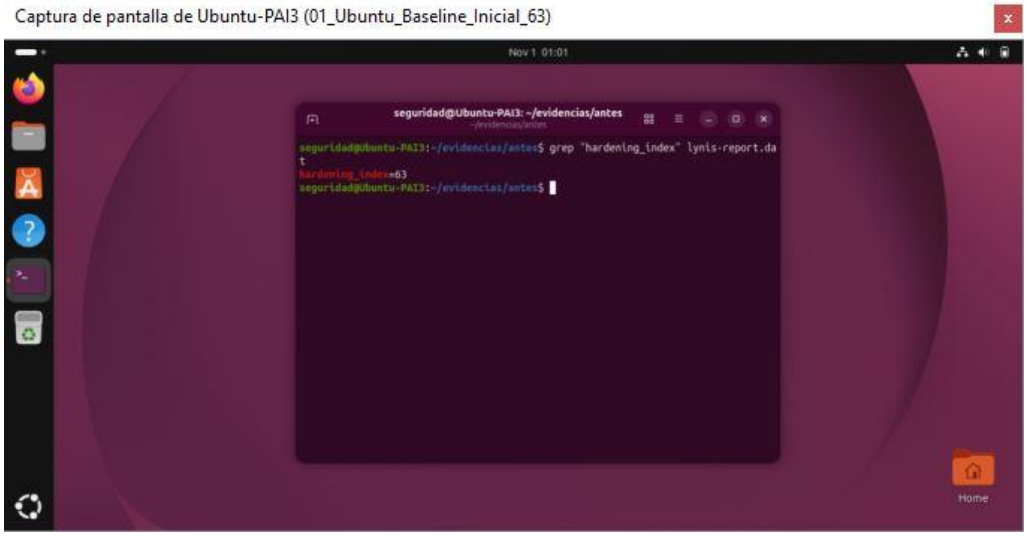
4. Reducción de la superficie de ataque y optimización del análisis

- **Restricción de binarios de desarrollo:** Se modificaron los permisos de acceso a ensambladores y compiladores del sistema (chmod 700 /usr/bin/gcc* /usr/bin/as), restringiendo su uso exclusivo a root para neutralizar intentos de compilación local de exploits tras una brecha de usuario estándar.
- **Ajuste del perfil de auditoría:** Se configuró /etc/lynis/custom.prf para descartar pruebas de hardware físico-irrelevantes en máquinas virtuales.

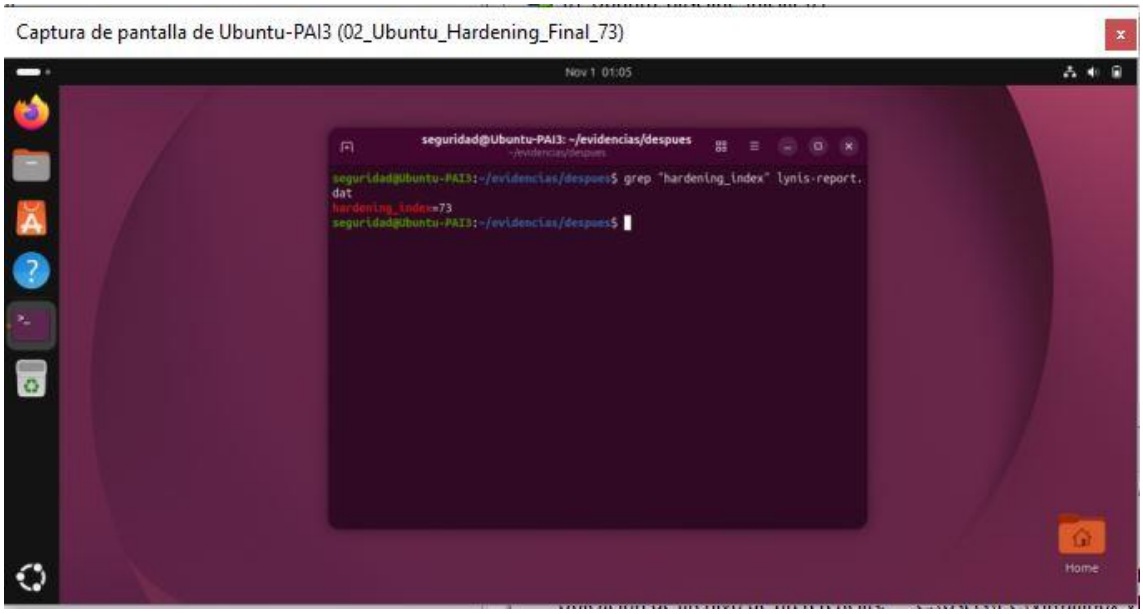
Resultados Cuantitativos Obtenidos

La aplicación coordinada de estas contramedidas permitió elevar el índice de bastionado por encima del umbral mínimo exigido (≥ 70) en ambos sistemas operativos:

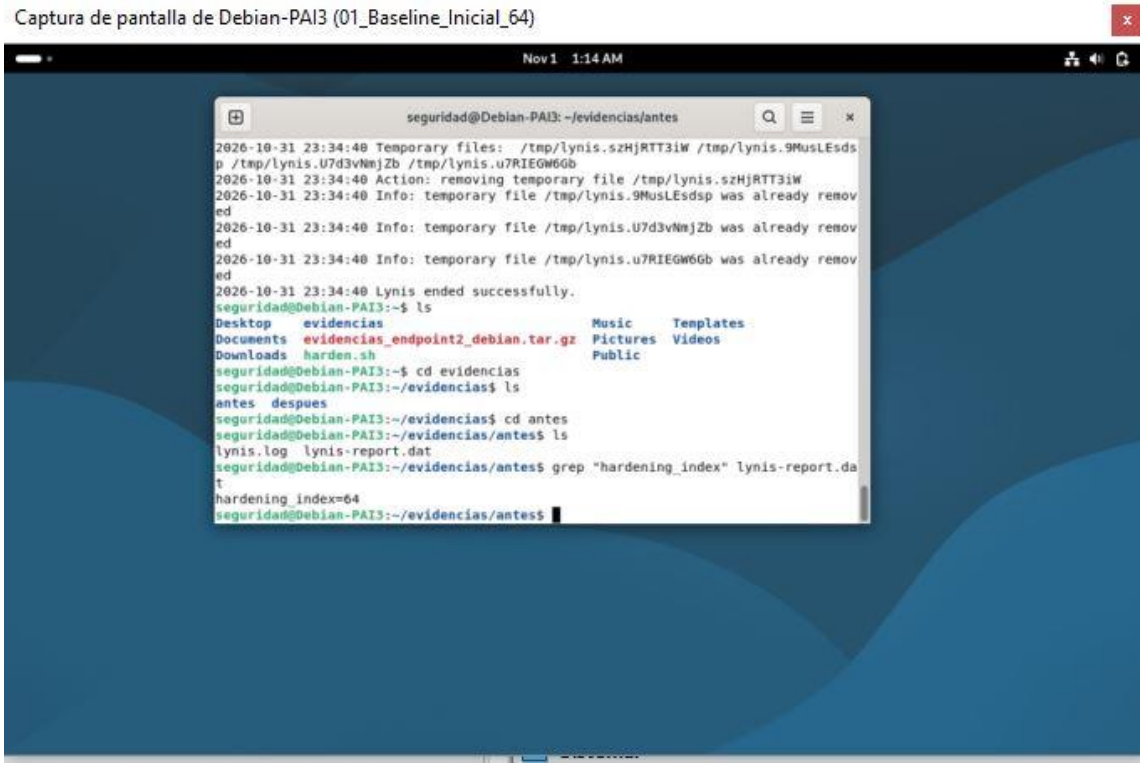
Endpoint	Sistema Operativo	Hardening Index Inicial	Hardening Index Final	Variación Absoluta	Estado del Requisito (≥ 70)
Endpoint 1	Ubuntu 24.04 LTS	63	**73**	+10 puntos (+15.87%)	**SUPERADO**
Endpoint 2	Debian 12 Bookworm	64	**70**	+6 puntos (+9.37%)	**SUPERADO**



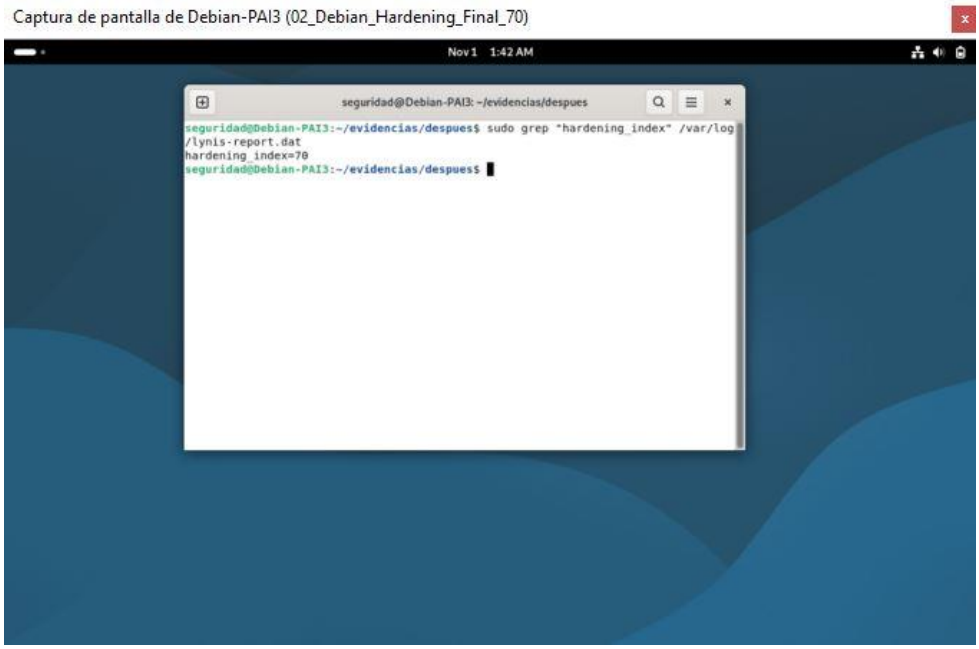
"Figura 3.3: Resultado cuantitativo inicial de Lynis en Ubuntu 24.04 LTS (Hardening Index: 63)")



"Figura 3.4: Resultado cuantitativo final de Lynis en Ubuntu 24.04 LTS tras aplicar hardening (Hardening Index: 73)")



"Figura 3.5: Resultado cuantitativo inicial de Lynis en Debian 12 Bookworm (Hardening Index: 64)")



"Figura 3.6: Resultado cuantitativo final de Lynis en Debian 12 Bookworm tras aplicar hardening (Hardening Index: 70)")

3.3. Conclusiones

La auditoría inicial evidenció que tanto Ubuntu 24.04 como Debian 12 presentan de forma nativa configuraciones orientadas a la interoperabilidad y a la facilidad de uso, sacrificando controles de seguridad esenciales como la restricción de llamadas al kernel, el filtrado perimetral por defecto o la complejidad en la autenticación local.

El plan de bastionado implementado permitió elevar sustancialmente la resiliencia de ambas plataformas sin degradar los servicios esenciales del sistema operativo. Las contramedidas en red (UFW y parámetros sysctl contra spoofing y flooding), la contención de memoria en el espacio de usuario (kptr_restrict) y la neutralización de compiladores locales cerraron los vectores habituales de intrusión y movimiento lateral. Con unos incrementos de 10 puntos en Ubuntu y 6 puntos en Debian, ambos entornos superaron los criterios de corte establecidos para el proyecto, quedando todas las trazas brutas y evidencias empaquetadas en sus respectivos archivos.tar.gz para verificación externa.